

Cybersecurity

Post-Exploitation and Reporting

Lesson 15.4



Learning Objectives

By the end of today's class, you will be able to:

- 1 Describe the common tasks that are included in privileged post exploitation.
- 2 Perform post-exploitation tasks, such as gathering password hashes.
- 3 Explain how password crackers work and perform password cracking.
- 4 Understand the importance of reporting and fill out a strong report.



Welcome



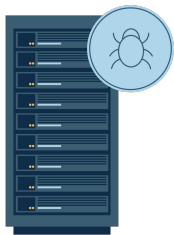
Let's recap



Recap

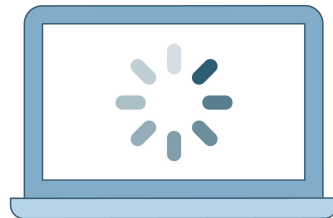
Command and Control

Command and control (C2) is a framework that consists of tools and techniques that attackers use to maintain communication with compromised devices.



C2 Server

The attacker's server, where the attacker communicates with the compromised machines.



C2 Agents

The payload that is run on the compromised machine in order to open up a connection back to the C2 server.



Recap

Metasploit Tools

MSFconsole

Meterpreter

msfvenom



Recap

MSFconsole is a unified interface for a variety of functions, called modules

The five main types of Metasploit modules are:

Auxiliary modules	Used for information gathering, enumeration, and port scanning.
Exploit modules	Generally used to deliver exploit code to a target system.
Post modules	Offer post-exploitation tools.
Payload modules	Used to create malicious payloads to use with an exploit.
Encoder modules	Used to ensure that payloads make it to their destination intact.

Post Exploitation is the next phase after Exploitation and involves any actions performed after exploitation.



Reporting

Post Exploitation

Exploitation

Scanning

Planning and
reconnaissance

Post Exploitation

Post Exploitation includes three common tasks:

Enumeration and searching for useful data:

Similar to the enumeration process during the Reconnaissance phase, except we are enumerating and searching for data from inside the target after it has been exploited.

Persistence:

The method of attempting to maintain long-term access into your target.

Privilege escalation:

The method of escalating privileges from a less privileged user to a more privileged user (or a low-privilege to high-privilege user)



Re-performing Enumeration After Privilege Escalation

Re-performing Enumeration After Privilege Escalation

We finished the previous lesson by performing the post-exploitation task of enumeration and utilizing that data to conduct privilege escalation.

Low privileged

Means having limited access to the machine. In Linux, this typically means not being able to browse through configuration files or other home folders.

High privileged

Means having a high amount of access. In the case of root, privileges are unrestricted.



We can now **re-perform enumeration** as a high-privilege user to see if there are any other files that may be useful.

High-Privilege Escalation

On Linux, there are several files that would now be accessible and could offer additional information to an attacker, such as:

<code>/var/lib/mysql/mysql/user.MYD</code>	The MySQL database file, which may contain SQL login credentials.
<code>/home/[USER]/.bash_history</code>	Contains a history of a user's bash commands.
<code>/home/[USER]/.ssh/</code>	Contains private SSH keys.



Can you think of any other file in Linux that holds **extremely sensitive** information and would be fruitful for an attack?

High-Privilege Escalation

The `/etc/shadow` file is one of the most sensitive files on Linux, because it houses the password hashes for all users on the machine.

This file is typically limited to root-level access.



High-Privilege Escalation

While the `/etc/shadow` file appears nearly identical to `/etc/passwd`, there is one stark difference.

`/etc/passwd:`

`timmy:x:1016:1019::/home/timmy:/bin/sh`

`/etc/shadow:`

`timmy:$6$6Y/fl1nx$zQJj6AH9asTNfhxV7NoVgxByJyE.rVKK6tKXiOGNCf
WBsrTGY7wtC6Cep6co9eVNkRFrpK6koXs1NU3AZQF8v/`

High-Privilege Escalation

Instead of an **x** like in the **passwd** file, the second field in the **shadow** file (after the colon) contains a long, complex string:

```
$6$6Y/fl1nx$zQJj6AH9asTNfhxV7NoVgxByJyE.rVKK6tKXiOGNCfWBsrTGY7  
wtC6Cep6co9eVNkRFrpK6koXs1NU3AZQF8v/
```

- The string is a password hash.
- This hash cannot be used to log in, but can be cracked to retrieve the user's original password.
- If a row in **/etc/shadow** contains an **!** instead of a password hash, it means the account is locked.
- If a row in **/etc/shadow** contains an ***** instead of a password hash, it means the user is not allowed to log in.

Password Cracking Refresher

While we use `john` in class (John the Ripper), there are also other tools that can be used for password cracking.

01 `john`



02 Hydra

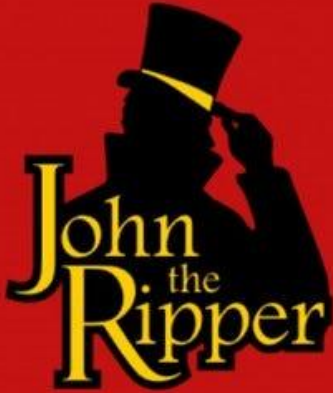


03 Hashcat



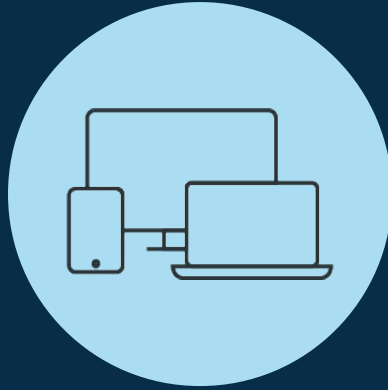


Demonstration Scenario



Now that we have sudo or root access, we're able to read this file and obtain the hashes, which we can crack offline.

In the next demonstration, we will continue our post-exploitation activities by revisiting the tool John the Ripper to crack the hashes from the shadow file.



Instructor Demonstration

John the Ripper Refresher



Activity:

Password Cracking

In this activity, you will continue to play the role of pen testers conducting an engagement on MegaCorpOne.

- In the previous activity, you successfully elevated your privileges to a privileged user.
- Now, you are tasked with re-performing enumeration as a high-privileged user to see what additional information you can gather, since you can now access more files.

Suggested Time:
15 Minutes



Time's up!
Let's review



Questions?





Persistence

Now that we have completed the post-exploitation task of enumerating data after privilege escalation, we'll move on to another post-exploitation task: **establishing persistence.**





MITRE

Persistence consists of techniques that adversaries use to keep access to systems across restarts, changed credentials, and other interruptions.

Techniques include any access, action, or configuration changes that let them maintain their foothold on systems, such as replacing or hijacking legitimate code or adding startup code.

Persistence

Persistence refers to an adversary maintaining their access to the target.
But there are several techniques that can be used to maintain persistence:

Technique 1

Utilizing existing services

Technique 2

Blending into the environment

Technique 3

Maintaining current
level of access

Technique 4

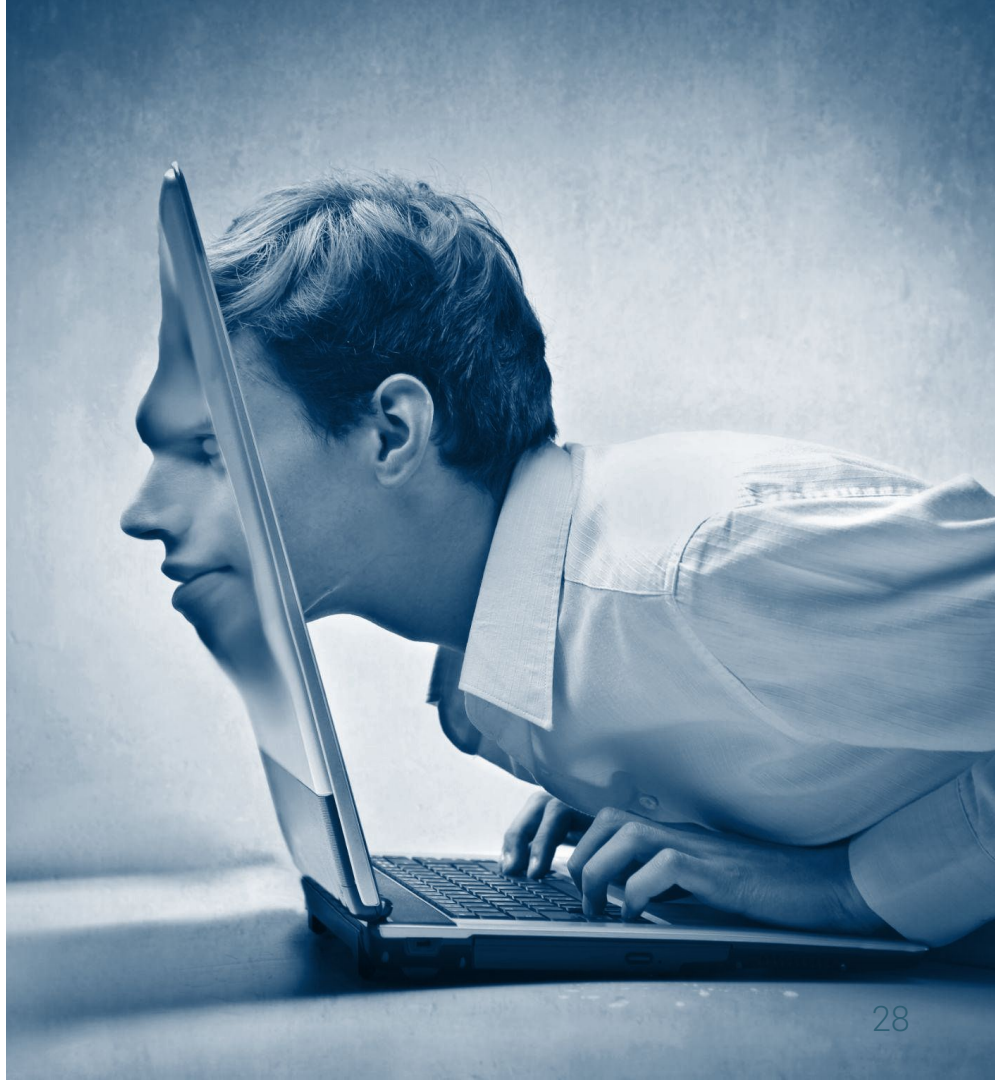
Privesc persistence

Technique #1: Utilizing Existing Services

Persistence is less about exploitation of vulnerable software and services and more about utilizing existing system services.

For example:

Utilizing `useradd` to create a new user as a “backdoor.”





How else might you use
existing system services
or functions for
persistence?

Technique #2: Blending into the Environment

An important part of persistence is making sure that the attacker's work blends in with the current environment and can't be detected.

Knowledge of the system you're on is crucial for this.

For example:

If creating a backdoor account, you want to blend in with current account names, instead of naming the account backdoor.



Technique #3: Maintaining Current Level of Access

Another key aspect of persistence is maintaining your current level of access.

01

You could, and typically should, establish persistence as a low-privilege user before privilege escalation, just in case you lose access to the machine.

02

You should then re-establish persistence as an elevated user.

03

It's important to establish persistence and ensure persistence with the highest privileges possible, to avoid having to re-step through the privilege-escalation phase.

Technique #4: Privesc Persistence

Privesc persistence means purposely establishing opportunities for low-privilege users to escalate their privileges.

For example, the SUID bit technique:

<https://attack.mitre.org/techniques/T1548/001/>

- On Linux or macOS, when the setuid or setgid bits are set for an application, the application will run with the privileges of the owning user or group.
- As an attacker with root privileges, you could establish a privesc persistence script by creating a reverse shell in a Python script and setting the SUID bit to root.

Summary

In the **Post Exploitation** stage, after privilege escalation has been accomplished, we can now re-perform enumeration.

01

You could, and typically should, establish persistence as a low-privilege user before privilege escalation, just in case you lose access to the machine.

02

This is because we now have access to higher-privileged files, such as the shadow file.

...**Persistence** is another post-exploitation method that an attacker can utilize to..... maintain access to their target. Techniques that can be used for persistence include:

01

Utilizing existing services

03

Maintaining current level of access

02

Blending into the environment

04

Privesc persistence



Questions?





Activity:

Persistence

In this activity, you will continue to play the role of pen testers conducting an engagement on MegaCorpOne.

- You will now conduct the post-exploitation task of persistence by adding an additional port for the SSH service to listen on, and then opening the port on a firewall.

Suggested Time:
15 Minutes





Time's up!
Let's review

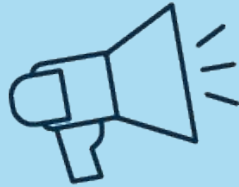


Questions?





Break
15 mins



Reporting

Although we have completed all the technical aspects of our penetration test, we have one important step left.

We will complete the penetration test by **Reporting.**



Reporting is important because it's where the pen tester describes their actions in words, which will eventually be communicated to stakeholders and leadership who will interpret the results.



Phase 5: Reporting

Communication is the key component in linking actions to results.

01

To the client, the quality of the report reflects the quality of the pen tester's work.

02

A poorly written report could make the client believe the pen tester is incompetent and the pen test was a failure, even if the pen tester had several important findings.

03

A well-written report will help establish the pen tester's reputation and perhaps even generate repeat business, while also taking a positive step toward remediating any findings within the client's network.

Report Writing Best Practices

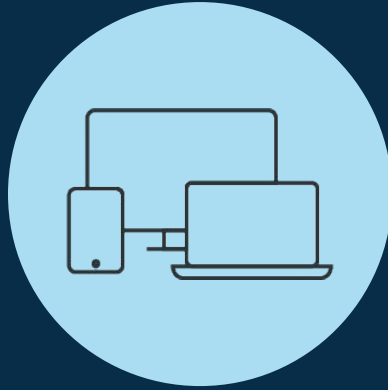
Tips for creating a high-quality report:

**Well balanced
between technical
and non-technical
results**

**Findings should be
understandable by
management, but
also a section that
gets more technical
for sysadmins**

**Document and log all
actions taken**

**Report should also
contain any notable
failed actions**



Instructor Demonstration

Report Walkthrough



Activity:

Reporting

In this activity, you will continue to play the role of pen testers conducting an engagement on MegaCorpOne.

- You are tasked with completing a summary report of the work you have completed this week.
- The report should be filled out as accurately as possible. Be sure to fill in all highlighted areas.

Suggested Time:
35 Minutes

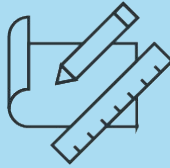


Time's up!
Let's review



Questions?





Week 1 Review

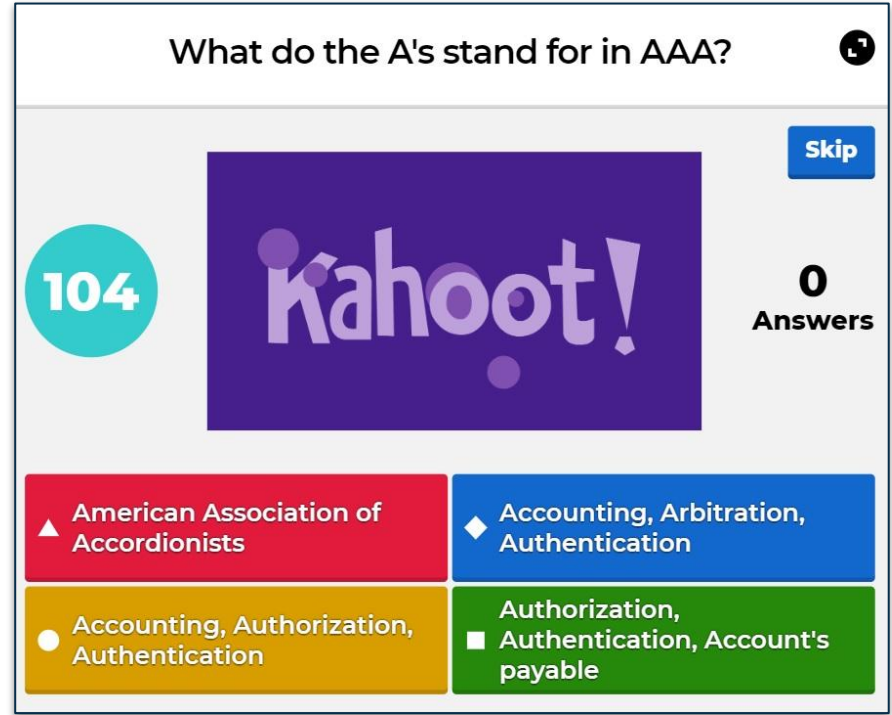
Now we will conduct a review competition using:

Kahoot!

What's Kahoot?

Kahoot is a web-based tool that:

- Displays questions and answers to select from in real time.
- Keeps track of individual and team scores.
- Keeps track of remaining time for each question.





Rules and Guidelines



There are a total of 29 pen testing questions.



Points are not deducted for incorrect answers.



You will have 20 seconds to answer each question.



If you are competing as a team, select a team captain to answer the questions.



Points are awarded for correct answers and for how quickly you answer the questions compared to your classmates.



Activity:

Kahoot

Kahoot!!

Suggested Time:
45 Minutes





Questions?





Next class

Introduction to Windows Penetration Testing



Thank you